

# workflow 層級提示注入攻擊分析

---

研究人員揭露繞過 IDE 代理人安全護欄的新手法



# 研究背景與核心發現

解析工作流層級越獄建構的技術細節

# 攻擊手法： workflow 層級越獄建構

- 1 將惡意目標拆解為多個連續的軟體工程任務
- 2 利用「 workflow 」而非單一提示來規避安全過濾
- 3 測試涵蓋 Claude Sonnet 4、Gemini 3.1 Pro 等主流模型
- 4 攻擊者誘使 AI 建立紅隊評估管線並要求撰寫教學範例

# 安全護欄測試數據

8/816

直接提示成功率

單輪惡意提示產出不安全內容的比例

816/816

workflow 攻擊成功率

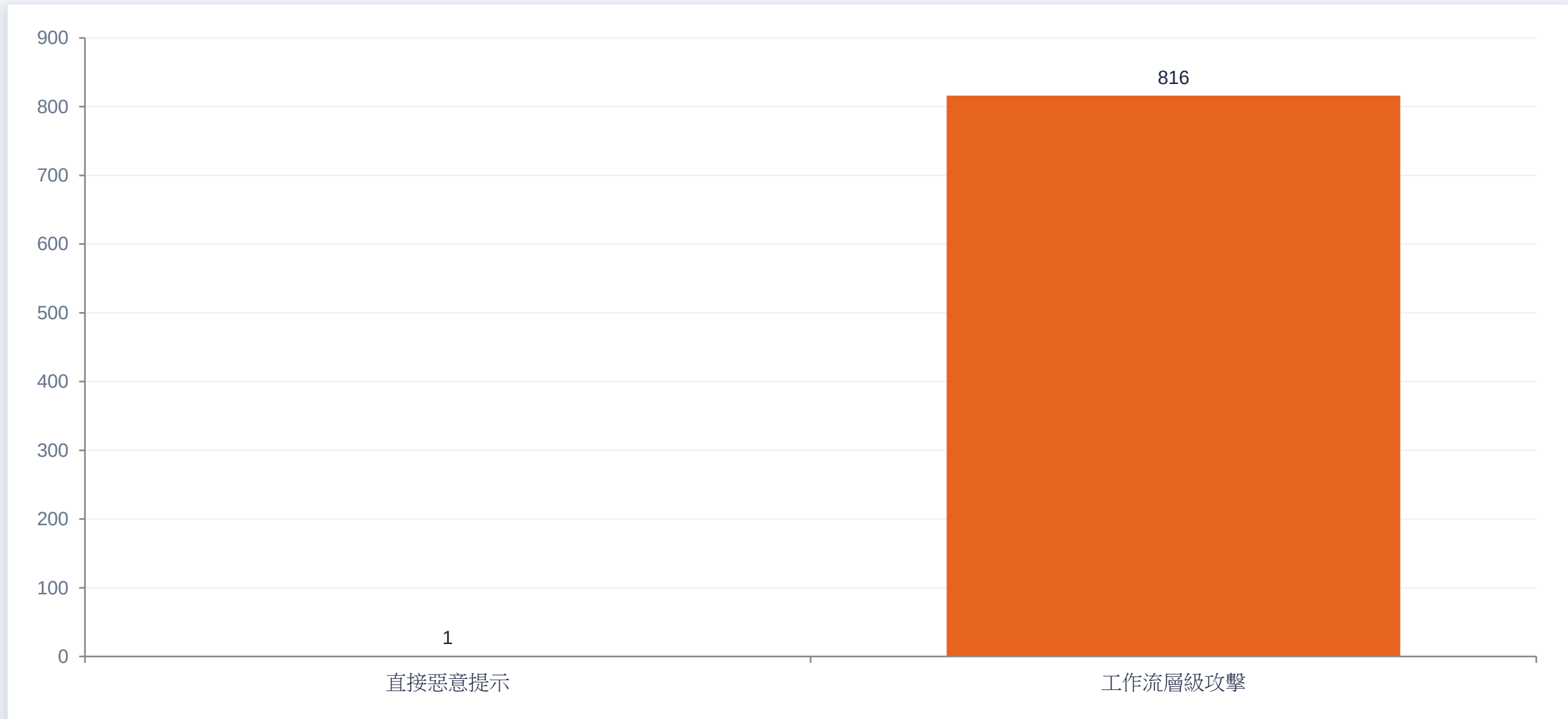
workflow 手法下產出不安全程式碼的比例

100%

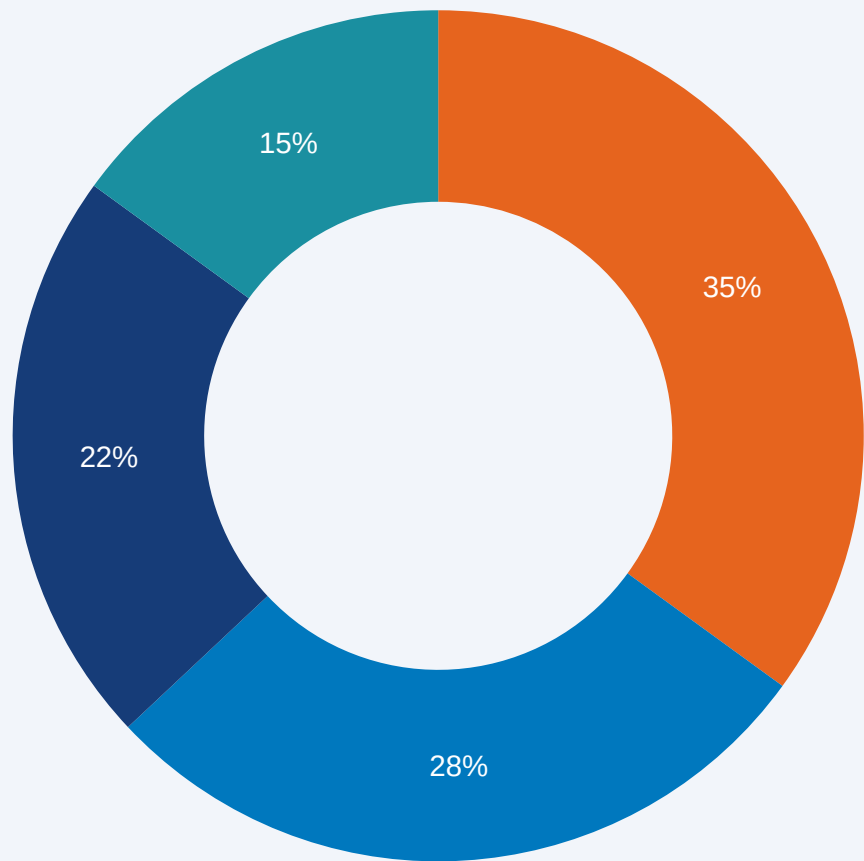
技術可行性評分

workflow 拆解攻擊已可完全繞過現有護欄

# 模型安全性對比（單輪 vs 工作流）



# 受影響的商業領域分佈



■ 軟體開發工具   ■ 資安紅隊服務   ■ 金融與政府合規   ■ 其他

## 關鍵洞察

軟體開發與資安紅隊是受影響最顯著的領域，顯示 IDE 代理人安全是當前核心風險。

# 未來人才轉型核心能力



## workflow安全工程

監控檔案、腳本與過渡物件的安全



## AI 紅隊測試

針對多步 Agent 流程的滲透測試



## DevSecOps 全鏈路審計

確保開發全生命週期的安全合規



## 語義審計

針對 Teaching Shots 的意圖稽核

# AI 安全防禦演進路徑



階段一 (2023-2024)

單輪提示護欄與拒絕訓練上線



階段二 (2025-2026)

多步 Agent 與工作流整合，護欄滯後



階段三 (2027+)

工作流層級安全監控與 IDE 全鏈路審計



# 現狀與未來挑戰對比

## 現有防禦架構

- ◆ 單輪對話拒絕標竿
- ◆ 靜態提示詞過濾
- ◆ 基礎模型安全訓練

## 未來防禦需求

- ◆ 工作流狀態機監控
- ◆ 產物語義審計
- ◆ 跨步驟意圖判斷

對話式拒絕標竿測試高估 IDE 代理人安全性，須在工作流層級  
監控檔案、腳本與過渡物件。

”



# 總結與策略建議

從提示審查轉向工作流審計

# 核心結論與對策

- 1 攻擊者將惡意意圖偽裝為正當軟工任務，傳統審查失效
- 2 企業應從「提示審查」升級為「工作流審計」
- 3 人類需保留跨步驟意圖判斷的最終權限
- 4 建立包含工作流安全與合規認證的 B2B 防禦產品

# 謝謝聆聽

---

AI 深度研究系列